Progetto Build Week 1

Progetto Di Rete: Theta

Team Firewall Quintana

30/10/2026

Introduzione

La squadra **Firewall Quintana** (composto dai Signori: **Alessandro, Capranica, Sinacori, Reinaudi, Bozzuffi, Salvato**) è stata assegnata allo svolgimento per la realizzazione di un preventivo di spesa e progetto per la compagnia Theta e per la loro infrastruttura IT.

Programmi Utilizzati

- **Cisco Packet Tracer;**
- **Oracle VirtualBox;**
- **Kali Linux;**
- **Visual Studio Code;**
- **Metasploitable 2;**

1 - Specifiche del Progetto

1.1 Requisiti e Componenti Necessari:

- **Struttura dell'edificio**: 6 piani
- **Dispositivi previsti**: 20 computer per piano, per un totale di 120 computer
- **Componenti aggiuntivi**:
- 1 Web server (rappresentato dalla macchina DVWA di Metasploitable)
- 1 Firewall perimetrale
- 1 Nas (Network Attached Storage)
- 3 IDS/IPS (Intrusion Detection System / Intrusion Prevention System)

1.2 Rete interna Aziendale

- **Switch per ogni piano**: Collegare i 20 computer di ciascun piano a uno switch dedicato.
- **Router**: Collegare tutti gli switch dei vari piani a un router centrale.
- **Firewall**: Posizionare il firewall perimetrale tra il router interno e la connessione a internet.
- **NAS**: Collegare il NAS allo switch al piano terra (vicino al router) per garantire l'accesso ai dati da parte di tutti i computer aziendali.
- **IDS/IPS**: Implementare 3 IDS/IPS nel perimetro interno per monitorare il traffico di rete e prevenire intrusioni.

1.3 Rete Esterna (Internet)

- **Connessione ad Internet**: Collegare il firewall perimetrale a Internet.
- **Web Server**: Posizionare il web server (DVWA di Metasploitable) nella zona demilitarizzata (DMZ) tra il firewall e la connessione a internet, garantendo così un accesso sicuro dall'esterno.

1.4 Testing Della Rete

- **Verifica dei Verbi HTTP:** Scrittura di un programma Python per inviare richieste HTTP (GET, POST, PUT, DELETE) al web server e verificare e risposte.
- **Scansione delle Porte**: Utilizzo di un programma Python per eseguire una scansione delle porte sui dispositivi di rete, verificando la sicurezza e l'accessibilità delle varie porte di comunicazione.

Questo approccio garantirà che l'infrastruttura di rete della compagnia Theta sia ben progettata, sicura e pronta per operare in modo efficiente.

2 - Topologia dell’infrastruttura di Rete

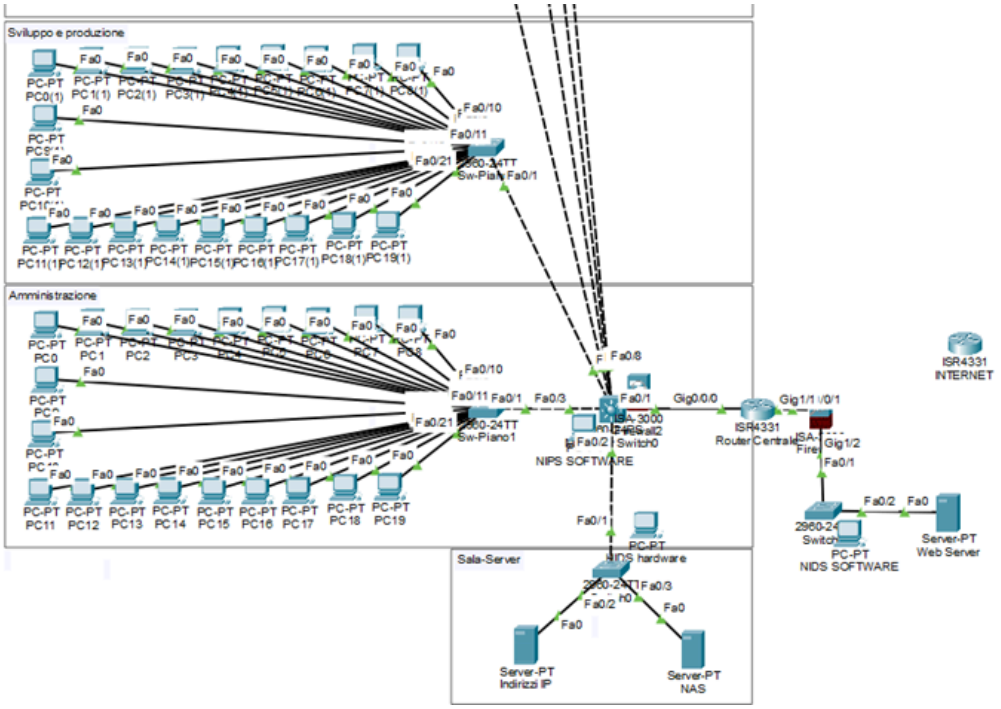
2.1 - Introduzione e visione d’insieme

Per rispettare al meglio le richieste dell’azienda, abbiamo sviluppato un progetto che potesse garantire la massima qualità dal punto di vista dell’infrastruttura di rete e della sua sicurezza, con un occhio di riguardo anche alla spesa finale del committente, grazie all’aiuto del nostro esperto di marketing. Per questo motivo, tutte le scelte sono state prese dopo un’attenta analisi di questi fattori.

Di seguito verrà fornita una breve panoramica della struttura:

- **Suddivisione dei piani**: l’edificio si sviluppa su 6 livelli, ognuno dei quali ospita un’area aziendale differente:
    - ❖ Piano1 (Amministrazione e risorse umane)
    - ❖ Piano2 (Sviluppo e produzione)
    - ❖ Piano3 (Marketing e vendite)
    - ❖ Piano4 (Servizi ospiti)
    - ❖ Piano5 (Logistica)
    - ❖ Piano6 (Tech)

- **Topologia della rete**: l’infrastruttura di rete si basa su una **topologia a stella estesa**. Questa architettura garantisce modularità, facilità di gestione del traffico e isolamento dei domini di broadcast per ciascun piano dell’edificio, risultando più sicura.



2.2 - Architettura e cablaggio

Ciascun piano è stato fornito di uno switch (livello 2) a cui fanno capo 20 postazioni di lavoro (PC). A loro volta, ogni switch di piano è stato collegato ad un unico switch centrale di layer 3 posizionato al piano terra, collegato al router e alla sala server.

La scelta di utilizzare uno switch di layer 3 come fulcro della topologia permette di concentrare in un unico punto la segmentazione del traffico delle varie sottoreti Vlan, senza sovraccaricare il router principale, ed evitando il famoso 'collo di bottiglia'. Questo grazie alla funzionalità di routing integrata in questo tipo di switch, che opera in un certo senso a livello di rete, assumendo il ruolo di gateway per le differenti sottoreti e gestendo l'instradamento inter-Vlan.

Una struttura di questo tipo permette infine al router di occuparsi del traffico di rete in uscita.

Struttura fisica:

- **Dispositivi Finali**: sono rappresentati dai pc, venti per ogni piano per un totale di centoventi. Ognuno di questi è stato collegato con un cablaggio fisico allo switch di piano: ogni dispositivo è in grado di collegarsi solo con i dispositivi di pari piano in virtù dell'architettura di rete.

- **Dispositivi di Distribuzione**: rappresentati dagli switch e router che gestiscono il traffico:
  - Switch (9): otto switch di layer 2, presenti uno per ogni piano e uno nella sala dei server, configurati ognuno con la proprio sottorete e uno nella DMZ; uno switch di layer 3.
  - Router: posizionato al piano terra, si occupa di gestire tutto il traffico di rete tra la rete interna (LAN) e quella esterna (WAN).

- **Dispositivi di sicurezza**: rappresentati dai Firewall e dagli IDS/IPS:
  - Firewall (2): il primo è un firewall hardware e fa da filtro tra la rete esterna e il router aziendale (rete interna) da un lato, e la DMZ dall'altra. Il secondo invece l'abbiamo implementato come software sullo switch per assicurare maggiore sicurezza all'intera rete interna, con un riguardo verso la sala server.
  - IDS/IPS (3): due IDS e un IPS, collocati in punti nevralgici per garantire una sicurezza in più.



- **Server**: sono stati utilizzati 3 server, ognuno con la sua funzione:
  - Server NAS: per lo stoccaggio dei dati aziendali.
  - Server degli Indirizzi IP: utile a fornire indirizzi IP a tutti i dispositivi aziendali tramite la sua funzione di DHCP.
  - Web Server: si trova nella DMZ, raggiungibile da tutti gli utenti sulla rete esterna.

- **Mezzi di Trasmissione**: l'intera infrastruttura di rete è stata realizzata esclusivamente su base cablata. Abbiamo volutamente evitato l'uso della tecnologia wirless in quanto, trattandosi di un grosso edificio, l'abbiamo ritenuta meno adeguata al progetto, rischiando di essere più soggetta a perdita di segnale e instabilità della rete. Invece, la scelta del cablaggio fisico garantisce la massima stabilità di connessione, un'elevata velocità di trasmissione del segnale a qualsiasi piano e un livello maggiore di sicurezza.

2.3 - Architettura Logica e Indirizzamento IP

Qui di seguito riportiamo una tabella con i dispositivi principali della rete e la loro configurazione:

Dispositivo	Interfaccia	Indirizzo IP	Subnet Mask	Gateway
Switch (lv.3)	FastEth0/1	192.168.255.2	255.255.255.252	
Router	GbitEth0/0/0	192.168.255.1	255.255.255.252	
Router	GbitEth0/0/1	172.16.0.2	255.255.255.252	
Firewall1	GbitEth1/1	172.16.0.1	255.255.255.252	
Firewall1	GbitEth1/2	140.27.6.2	255.255.0.0	
Web Server	FastEth0	140.27.6.3	255.255.0.0	140.27.6.3
Server IP	FastEth0	192.168.100.20	255.255.255.0	192.168.100.1
Server NAS	FastEth0	192.168.100.10	255.255.255.0	192.168.100.1
PC piano1	FastEth0	192.168.10.X	255.255.255.0	192.168.10.1
PC piano2	FastEth0	192.168.20.X	255.255.255.0	192.168.20.1
PC piano3	FastEth0	192.168.30.X	255.255.255.0	192.168.30.1
PC piano4	FastEth0	192.168.40.X	255.255.255.0	192.168.40.1
PC piano5	FastEth0	192.168.50.X	255.255.255.0	192.168.50.1
PC piano6	FastEth0	192.168.60.X	255.255.255.0	192.168.60.1

La rete è stata segmentata a livello logico tramite l'impiego di VLAN distinte per ogni piano, configurate sugli apparati di distribuzione switch. Per la gestione e l'assegnazione degli indirizzi IP alle 120 postazioni di lavoro distribuite sui vari piani si è scelto di implementare un

server DHCP (server Indirizzi IP). Questo server lavora in sinergia con lo switch di layer 3: infatti il sistema sfrutta la suddivisione in VLAN per fare in modo che il server DHCP possa erogare correttamente e in modo automatico i parametri di rete (indirizzo IP, subnet mask e gateway) ai computer dei vari piani, rispettando il subnetting.

2.4 - Configurazione dei Dispositivi di Rete

- **Switch centrale Layer 3** (Gestione VLAN):
  - ❖ Configurazione: sono state create e definite le VLAN di piano per segmentare il traffico dei sei reparti aziendali, isolando i domini di broadcast per ciascun gruppo.
  - ❖ Funzione: lo switch agisce come nucleo di sostituzione della rete locale, coordinando il flusso di dati proveniente dai sei switch di piano.

```
Switch>show vlan brief

VLAN Name                             Status    Ports
---- -------------------------------- --------- -------------------------------
1    default                          active    Fa0/10, Fa0/11, Fa0/12, Fa0/13
                                                Fa0/14, Fa0/15, Fa0/16, Fa0/17
                                                Fa0/18, Fa0/19, Fa0/20, Fa0/21
                                                Fa0/22, Fa0/23, Fa0/24, Gig0/1
                                                Gig0/2
10   Piano1                           active    Fa0/9
20   Piano2                           active
30   Piano3                           active
40   Piano4                           active
50   Piano5                           active
60   Piano6                           active
100  Sala-Server                      active
1002 fddi-default                     active
1003 token-ring-default               active
1004 fddinet-default                  active
1005 trnet-default                    active
```

- **Server DHCP** (Assegnazione Indirizzi IP):
  - ❖ Configurazione: è stato configurato un Server DHCP dedicato (denominato server Indirizzi IP), sul quale sono stati aggiunti, tramite il percorso Service > DHCP, i pool di indirizzi IP assegnati alle varie sottoreti di piano.
  - ❖ Funzione: automatizzare completamente la distribuzione dei parametri di rete agli host finali, garantendo una gestione centralizzata e priva di configurazioni manuali su ogni singola postazione.

Pool Name	Default Gateway	DNS Server	Start IP Address	Subnet Mask
Piano6	192.168.60.1	192.168.100.20	192.168.60.5	255.255.255.0
Piano5	192.168.50.1	192.168.100.20	192.168.50.5	255.255.255.0
Piano4	192.168.40.1	192.168.100.20	192.168.40.5	255.255.255.0
Piano3	192.168.30.1	192.168.100.20	192.168.30.5	255.255.255.0
Piano2	192.168.20.1	192.168.100.20	192.168.20.5	255.255.255.0
Piano1	192.168.10.1	192.168.100.20	192.168.10.5	255.255.255.0
serverPool	0.0.0.0	0.0.0.0	192.168.100.0	255.255.255.0

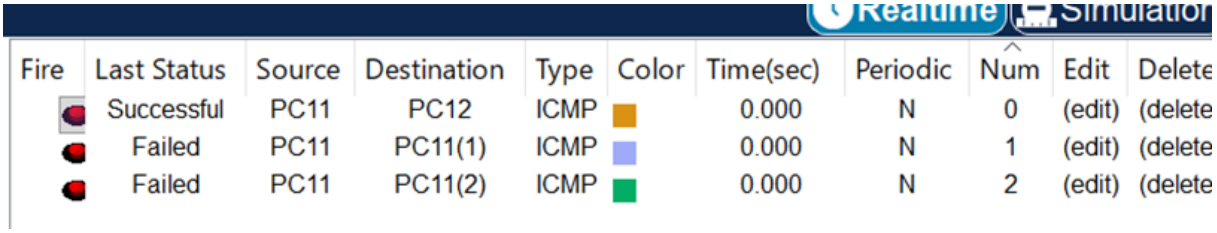
- **Router perimetrale**: grazie alla configurazione dello switch sopracitato, il router si limita a gestire la connessione alla rete; trovandosi da un lato sullo switch centrale e dall'altro verso il Firewall, funge da punto di passaggio per il traffico diretto verso la rete esterna.

- **Switch di Accesso Layer 2** (Piani e server):
  - ❖ Switch di piano (1-6): per ciascun piano dell'edificio è stato impiegato uno switch standard di layer 2. Gestiscono il traffico locale delle venti postazioni di ciascun piano e lo inoltrano verso il nucleo centrale tramite collegamenti trunk.
  - ❖ Switch di server: un ulteriore switch gestisce l'infrastruttura server, collegandoli direttamente al nucleo centrale.

- **Postazioni utente** (PC): l'infrastruttura serve complessivamente 120 postazioni di lavoro. Ogni pc riceve dinamicamente i parametri di rete necessari direttamente dal server tramite il servizio di indirizzamento automatico.

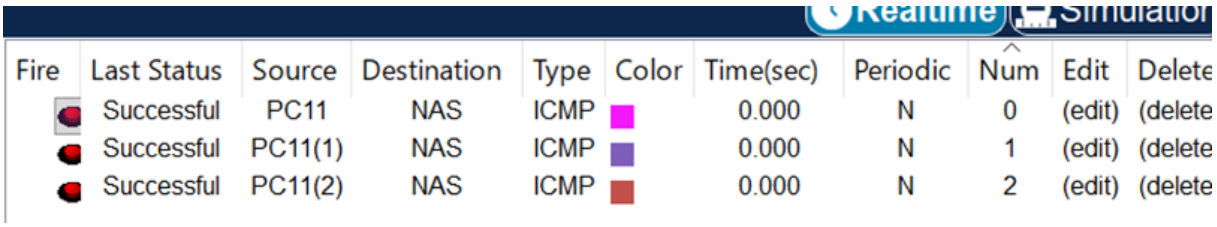
2.5 - Test di Connettività e Verifica

Al termine della configurazione, sono stati eseguiti test di verifica tra i vari dispositivi della rete. I test hanno dato esito positivo, confermando la piena connettività: le postazioni dello stesso piani riescono a comunicare correttamente tra loro attraverso lo switch, risultando scollegati da quelli degli altri piani, così come risultano perfettamente raggiungibili i server di servizio e il NAS, validando il corretto funzionamento dell'instradamento e dell'assegnazione dinamica degli indirizzi IP.



Fire	Last Status	Source	Destination	Type	Color	Time(sec)	Periodic	Num	Edit	Delete
	Successful	PC11	PC12	ICMP		0.000	N	0	(edit)	(delete
	Failed	PC11	PC11(1)	ICMP		0.000	N	1	(edit)	(delete
	Failed	PC11	PC11(2)	ICMP		0.000	N	2	(edit)	(delete

Scambio di dati tra pc dello stesso piano (Successful) e tra pc di piani differenti (Failed).



Fire	Last Status	Source	Destination	Type	Color	Time(sec)	Periodic	Num	Edit	Delete
	Successful	PC11	NAS	ICMP		0.000	N	0	(edit)	(delete
	Successful	PC11(1)	NAS	ICMP		0.000	N	1	(edit)	(delete
	Successful	PC11(2)	NAS	ICMP		0.000	N	2	(edit)	(delete

I pc dei vari piani connettono perfettamente col server NAS.

2.6 - Sicurezza nella rete

2.6.1 - Firewall

Per proteggere al meglio la Rete d'azienda implementare **2 firewall**:

1. Il Primo (Hardware per non rallentare il server) va posizionato all'**esterno della rete interna, collegato alla rete DMZ e al router**. La rete DMZ è progettata per essere vista da tutti, ciò la rende un bersaglio comune. E' possibile però, aggiungendo delle regole al firewall, bloccare le porte non necessarie e quindi limitare le possibilità di una penetrazione all'interno della DMZ. Alcune delle porte fondamentali da tenere aperte sono le seguenti : pt. 80 (HTTP) e pt 443 (HTTPS) per il traffico web e la pt. 25 (SMTP) e pt. 465 (SMTPS) per servizi di E-mail ecco alcuni esempi di regole fondamentali da implementare sul firewall:

REGOLA	IP SORGENTE	IP DESTINAZIONE	PORTA	AZIONE
1	Qualsiasi	DMZ	80, 443	ALLOW
2	Qualsiasi	DMZ	25 , 465	ALLOW
3	DMZ	Qualsiasi	123, 80 , 443	ALLOW
4	DMZ	Qualsiasi	Qualsiasi	DENY
5	DMZ	Ip Database (LAN)	Porta del DB	ALLOW
6	DMZ	Mail Server (LAN)	Porta del MS	ALLOW
7	DMZ	IP LAN	Qualsiasi	DENY
8	Qualsiasi	Qualsiasi	Qualsiasi	DENY

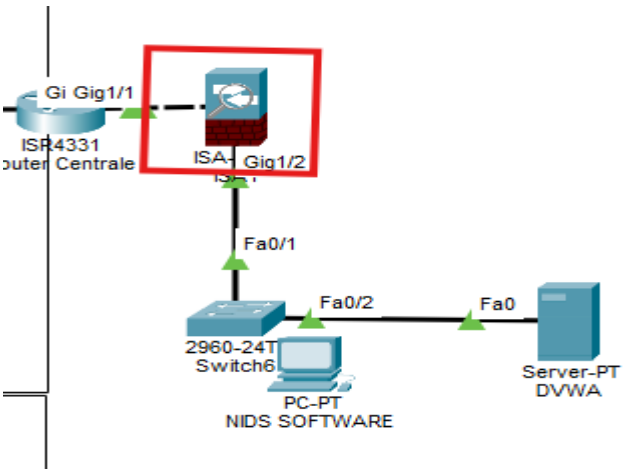
-reg. 3 per consentire alla DMZ di collegarsi ad internet solo per aggiornarsi porta 123 (NTP): sincronizzarsi all'orologio e porte 80 e 443 per scaricare patch di sistema e aggiornamenti in ambito sicurezza. Tutto il resto è bloccato dalla regola 4.

-le regole 5 e 6 permettono alla DMZ solamenti di collegarsi alla LAN interna per informazioni nel database e per il servizio E-mail tutto il resto che proviene dalla DMZ verso la LAN viene bloccata dalla regola 7

-regola 8 (HOC) dice che tutto quello che non rispetta le regole precedenti viene bloccato

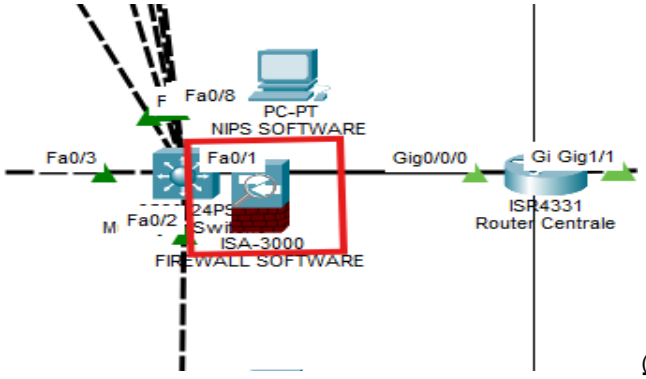
Inoltre attraverso il **filtraggio WAF** il firewall può controllare il contenuto delle richieste http/https e bloccarle se considerate sospette.

Questo firewall funge pure da prima linea di difesa della rete interna aziendale potendo bloccare le porte inutili e vulnerabili per l'azienda.



(rete esterna DMZ)

2. Il secondo invece protegge la sala server e l'intranet d'azienda (Software per ridurre costo) ed è **implementato sul multilayer switch interno alla rete**. Ha lo scopo di monitorare sia il traffico all'interno della rete aziendale (es.: da pc a server NAS) sia quello che proviene dall'esterno e se considerato sospetto verrà bloccato. Per fare ciò l'amministratore deve creare delle regole statiche che poi il firewall andrà a leggere e impedirà il traffico dei pacchetti che non le rispettano. (filtraggio statico)



(rete interna)

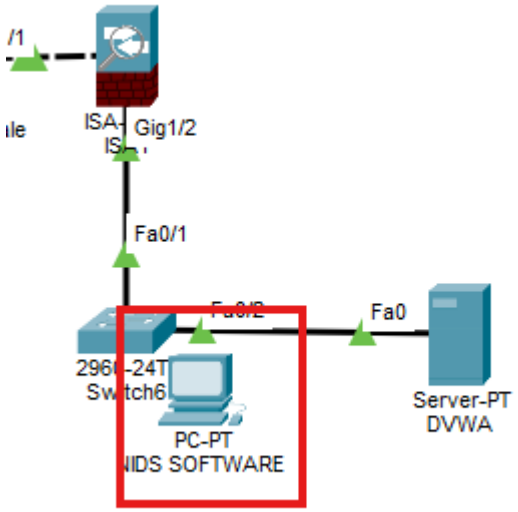
2.6.2 - IPS/IDS

Aggiungere **1 IPS e 2 IDS** come ulteriore linea di difesa:

1. Nella DMZ, sullo switch principale, va installato un **NIDS** (*Network Intrusion Detection System*). Siccome è un "Network" IDS ha il compito di analizzare il traffico di rete nella DMZ già filtrato dal Firewall e notificare l'amministratore nel caso riconosca un attacco o un comportamento anomalo mancato dal filtraggio del FW.

Questi scanner utilizzano infatti **pattern matching** per riconoscere metodi di attacco comuni e **Anomaly detection** per individuare comportamenti inusuali in una rete.

Per diminuire i costi usiamo uno scanner software sullo switch principale della DMZ.

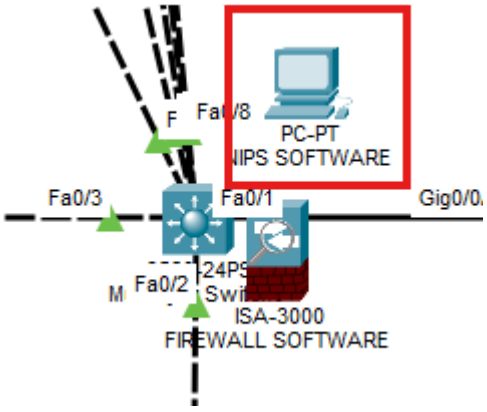


(rete esterna DMZ)

2. Il Secondo è un **NIPS** installato nel multilayer switch all'interno della rete. Funge da secondo controllo successivo al Firewall interno che controlla il traffico di tutta la rete. A differenza di un IDS non notifica l'amministratore ma blocca il problema rilevato direttamente.

Anche se **potrebbe creare falsi positivi** pensiamo che sia una linea di sicurezza in più necessaria siccome protegge tutta la rete. Richiede quindi, una maggiore attenzione, per poter analizzare il traffico bloccato dallo scanner e sbloccare eventuali falsi positivi.

Sempre per diminuire il costo usiamo un IPS software.



(rete interna)

3. Il Terzo è un **HIDS** con il compito di proteggere la sala server. E' un "**Host" IDS** che a differenza di quello "Network" ha il compito di controllare i Log e gli Accessi all'interno della sala Server. Nello specifico controlla:

   a) tentativi di Login falliti

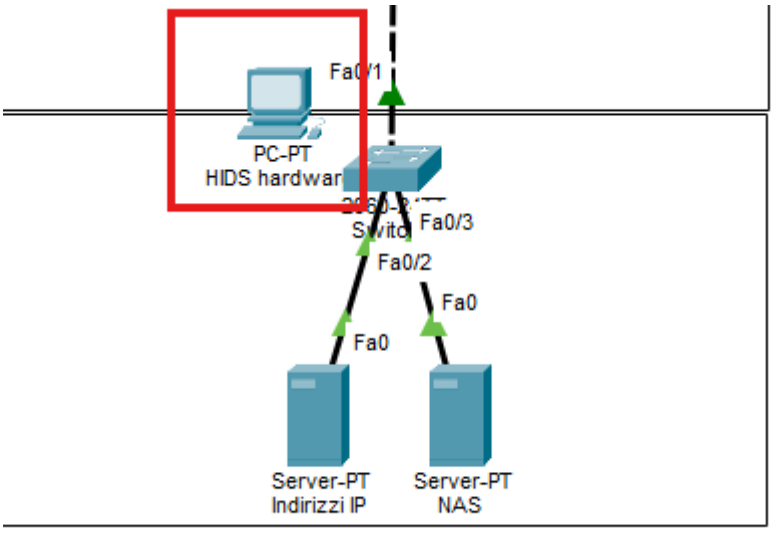
   b) modifiche nel server non autorizzate

   c) Accessi non autorizzati e successivamente notifica l'amministratore se rileva uno di questi problemi.

Siccome protegge una sottorete fondamentale per l'azienda utilizziamo uno **Scanner Hardware** che a differenza di quello software ha **prestazioni migliori** come:

a) Siccome è un dispositivo a parte non rallenta il dispositivo che protegge come quello software.

b) E' indipendente dai dispositivi che protegge, se un server viene compromesso, l'attaccante non può spegnere o manomettere il sensore, perché è un'altra macchina



(sala server rete interna)

3 - Testing Della Rete

3.1 - Verifica Dei Verbi HTTP

3.1.1 - Introduzione

Per testare i metodi **HTTP** supportati dal Web Server, verrà illustrata la procedura di **creazione e trascrizione di un programma Python** usando la libreria **http.client**. Il programma richiede l'indirizzo IP (192.168.50.101) e il percorso da analizzare, verificando la risposta del server dei verbi (GET, POST, PUT e DELETE).

3.1.2 - Configurazione di Rete

A seguito la configurazione delle rete (per la simulazione):

Macchina Utilizzata	Ruolo	Indirizzo IP
Kali	VM da cui viene lanciato il programma	IP: 192.168.50.100
Metasploitable 2	Web server di Theta, porta 80	IP: 192.168.50.101

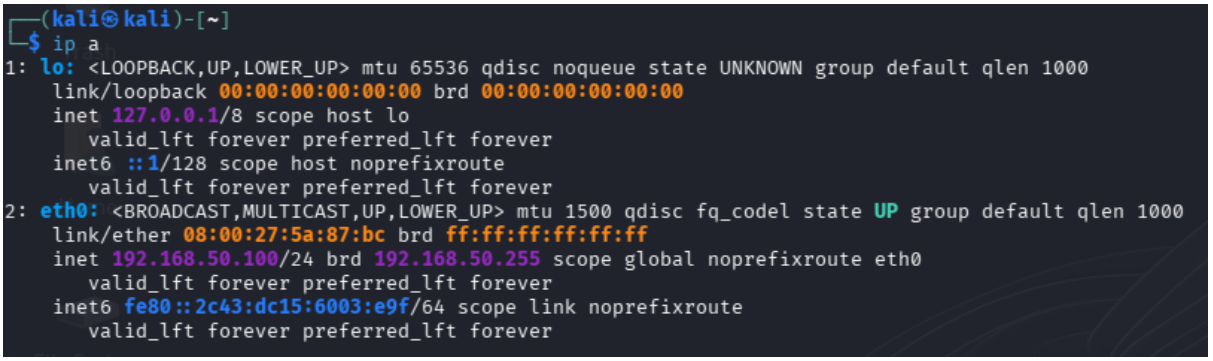


Figura 1 - IP Kali Linux (192.168.50.100)

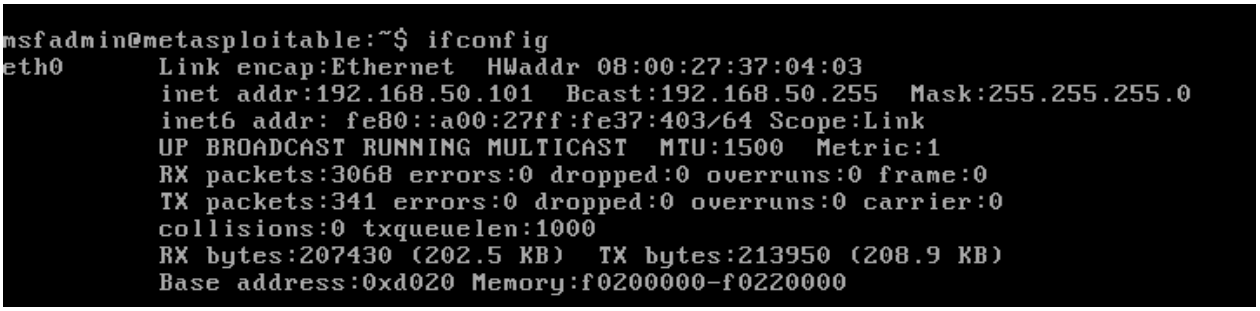


Figura 2 - IP Metasploitable 2 (192.168.50.101)

3.2 - Procedimento

In questo capitolo viene descritto il funzionamento del programma Python **(Figura 3)** per verificare quali verbi HTTP accetta il web server:

```python
import http.client
# inserisci l'ip di Metasploitable
ip = input("Inserisci l'IP del web server: ")
# inserisci il path della pagina da testare, per esempio /phpMyAdmin/
path = input("Inserisci il Path: ")
# lista dei verbi da provare
verbi = ["GET", "POST", "PUT", "DELETE"]
# lista vuota dove metteremo i verbi che il server accetta
abilitati = []
# ciclo for (ripetizione per ogni verbo della lista)
for verbo in verbi:
    # apro una connessione IP verso la porta 80, con attesa massima di 2 secondi
    conn = http.client.HTTPConnection(ip, 80, timeout=2)
    # mando al server la richiesta con il verbo
    conn.request(verbo, path)
    risposta = conn.getresponse()
    print(verbo, risposta.status, risposta.reason)
    # se il codice è compreso tra 200 e 299, considera i verbi abilitati (Il server ha accettato la richiesta e non ha dato errore)
    if 200 <= risposta.status < 300:
        abilitati.append(verbo)
    conn.close()

print("Metodi abilitati:", abilitati)
```

Figura 3 - Codice Python

1. **Importazione della libreria**: è stata importata la libreria http.client di Python, che dà la possibilità di parlare con i server web. Abbiamo scelto http.client perché fa già parte della libreria standard di Python. Non è necessario installare pacchetti esterni, rendendo il programma subito eseguibile su qualsiasi computer che abbia Python installato, ideale in un contesto di penetration testing rapido;

2. **Input dell'utente**: il programma chiede l'indirizzo IP del server web (in questo caso 192.168.50.101) e il percorso (path) della pagina (ad es. /phpMyAdmin/);

3. **Lista dei verbi**: Vengono preparate due liste, la prima contiene i quattro verbi HTTP (GET, POST, PUT e DELETE) e la seconda, abilitati, uno spazio vuoto che permette l'inserimento dei verbi accettati dal server;

4. **Ciclo for**: Il ciclo for prende un verbo alla volta dalla lista e ripete lo stesso lavoro, in maniera tale che non si debba riscrivere il codice quattro volte.
   Per ogni verbo il programma apre una connessione verso il server, sulla porta 80 (quella del web) aspettando massimo 2 secondi. Serve a evitare che lo script rimanga "bloccato" all'infinito in attesa di risposta se il server è spento, lento o protetto da un sistema di blocco, rendendo il controllo molto più veloce ed efficiente;

5. **Stampa del verbo:** stampa il codice di risposta e il relativo testo (per esempio GET 200 OK);

6. **Verifica dei metodi abilitati:** Se il codice di risposta del server è compreso tra 200 e 299 (ovvero la richiesta è andata a buon fine e non ci sono stati errori o blocchi), il verbo viene considerato "abilitato" e aggiunto alla lista finale.

Abbiamo scelto i codici da 200 a 299 perché, nello standard HTTP, sono i codici di successo: il server ha accettato la richiesta. Gli altri codici, come 302 (reindirizzamento), 404 (pagina non trovata) o 405 (metodo non permesso), non indicano un'accettazione, quindi non li contiamo come abilitati.

7. **Output finale:** Al termine del ciclo, il programma chiude la connessione e stampa a schermo la lista completa dei verbi HTTP accettati dal percorso analizzato;

3.3 - Risultati Dei Test

Il programma è stato eseguito da Kali sull'indirizzo 192.168.50.101, uno alla volta, sui path corrispondenti ai link della pagina di Metasploitable 2. A seguito i dettagli:

Path	GET	POST	PUT	DELETE	Metodi abilitati
/phpMyAdmin/	200	200	200	200	GET, POST, PUT, DELETE
/twiki/	200	200	405	405	GET, POST
/mutillidae/	200	200	200	200	GET, POST, PUT, DELETE
/dvwa/	302	302	302	302	Nessuno
/dav/	404	404	405	405	Nessuno

200 = richiesta riuscita; 302 = Reindirizzamento; 404 = pagina non trovata; 405 = metodo non permesso

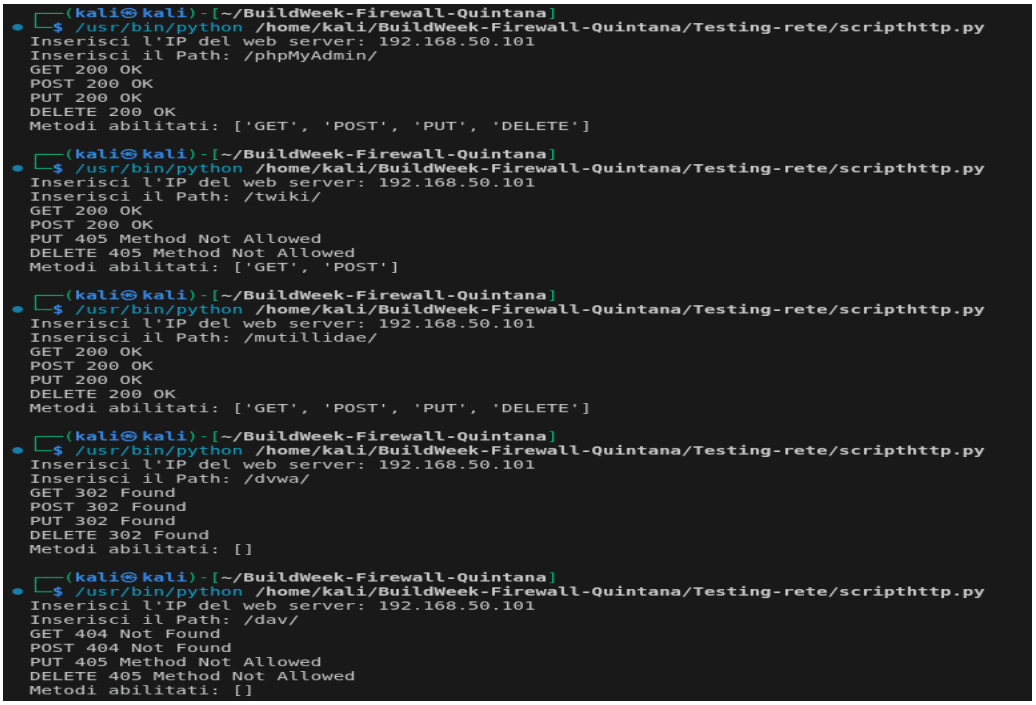


Figura 4 - Test dei 5 path

3.3.1 - Analisi dei risultati

- **phpMyAdmin e Mutillidae:** il server risponde 200 OK a tutti e quattro i verbi, quindi per il programma risultano tutti abilitati.
- **TWiki:** GET e POST sono accettati (200 OK), PUT e DELETE no (405 Method Not Allowed).
- **DVWA:** tutti i verbi ricevono 302 Found, cioè un reindirizzamento. Nessun verbo risulta abilitato. Probabilmente il server rimanda alla pagina di login, ma non l'abbiamo verificato.
- **WebDAV:** GET e POST ricevono 404 Not Found, PUT e DELETE ricevono 405. Nessun verbo risulta abilitato.

3.3.2 - Ultime Considerazioni

La risposta del server cambia a seconda del path. Solo TWiki rifiuta PUT e DELETE, mentre phpMyAdmin e Mutillidae li accettano. Attenzione: un codice 200 significa che il server ha accettato la richiesta, ma non significa che l'abbia eseguita.

3.4 - Scanner Delle Porte

Il seguente report illustra passo per passo l'ideazione, creazione e test di un programma in python dedicato alla scansione di porte su dispositivi di rete dato il loro IP, verificando lo stato e l'accessibilità delle varie porte di comunicazione. Sono infine presenti raccomandazioni per la sicurezza informatica aziendale.

3.4.1 - Codice portscanner

```python
# importa il modulo socket (modulo che da accesso all'interfaccia BSD)
import socket

# chiede IP all'utente
target = input("Inserire IP da scansionare: ")

while True:
    portrange = input("Inserire range di porte da scansionare (es: 6-7): ")
    # ricava le porte dall'input utente e le converte in numeri
    try:
    # int aggiunta necessaria per far accettare i numeri,
    # dato che python converte in stringhe altrimenti
        lowport, highport = (int(portnmbr) for portnmbr in portrange.split("-"))
    # se input non valido, torna a while
    except ValueError:
        print("Input non valido, usare ad esempio 6-7.")
        continue
    # ricorda all' utente quali porte sono valide
    if not (1 <= lowport <= highport <= 65535) :
        print("Le porte valide sono 1-65535")
        continue
    #input valido, fine ciclo while
    break

# autoesplicativo
print(f"Sto scansionando {target} dalla porta {lowport} alla porta {highport}...")

for port in range((lowport), (highport) + 1):
    # crea un socket (ipv4,TCP)
    s = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
    # non aspettare all'infinito (utile caso firewall), attesa 1s
    s.settimeout(1)
    # tenta la connessione al socket dell'ip, ritorna 0 se l'operazione ha successo
    status = s.connect_ex((target, port))
    # chiude il socket
    s.close()
    # controlla la situazione della porta confrontando gli errori (nr errori)
    # 1o nr linux, 2o nr windows
    if status == 0:
        result = "aperta"
    elif status in (111, 10061):
        result = "chiusa"
    elif status in (11, 10035):
        result = "timeout, forse filtrata dal firewall"
    else:
        result = f"Connessione fallita con codice: {status}"

    # stampa esito dello scan della porta
    print(f"Lo stato della porta {port} è: {result}.")

```

Il codice del portscanner è stato ideato ed ampliato gradualmente, testando le principali necessità ed esigenze della richiesta della compagnia Theta:

- Scritto interamente in python (Python 3.14.8), un linguaggio di programmazione ad alto livello, orientato ad oggetti, versatile e flessibile;
- Utilizza come metodo di connessione un socket ipv4 TCP (creato in riga 30) che utilizzeremo per testare la connessione e le porte del web server nella simulazione;
- È reso quanto più leggero possibile, grazie alla sua ottimizzazione contiene di fatto poche righe di codice ed un solo modulo importato (socket, riga 2), ma allo stesso tempo permette di ottenere un elenco completo dello stato di qualsiasi porta di un dato IP.

Sono stati inoltre aggiunti dei quality of life ritenuti necessari in un ambiente di test, come messaggi di errore dedicati in caso di input errato di porte (riga 15 a 17) e reminder all'utente del range di porte effettivamente valido (riga 19 a 21) (le porte utilizzate dal protocollo TCP vanno da 0 a 65535 e son tutte verificabili). Questi quality of life sono inclusi all'interno di un ciclo While True per assicurare la non interruzione del programma in caso di input errati.

Dato che, nella configurazione della topologia di sistema (come richiesto dalla compagnia Theta) che richiede l'inserimento di firewall, IDS e IPS, è stato incluso un timeout (riga 32), impostato ad 1 secondo, in caso di una ipotetica regola firewall.

È stato utilizzato connect ex (riga 34) per avere una stampa di errori numerici (error indicator) consultabili:

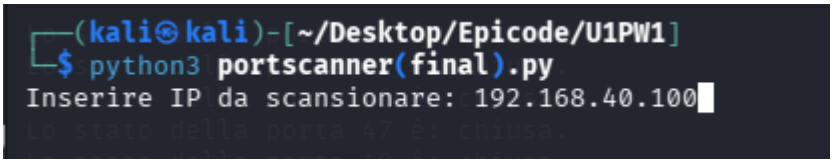
- 0 indica connessione avvenuta con successo (l'utente vedrà la porta come aperta);
- 111, 10061 indica una connessione rifiutata (l'utente vedrà la porta come chiusa);
- 11, 10035 indicano una connessione andata in timeout, possibile in caso di firewall ad esempio (l'utente vedrà la porta come andata in timeout, possibilmente filtrata dal firewall);
- tutti gli altri eventuali errori vengono stampati così come sono dal codice.

I numeri presenti sono i numeri di errori socket (da sinistra, primo numero per Linux, secondo numero per Windows) consultabili liberamente nelle seguenti fonti:
Linux Error Number Table (errno)
Windows Sockets Error Codes (Winsock2.h) - Win32 apps | Microsoft Learn

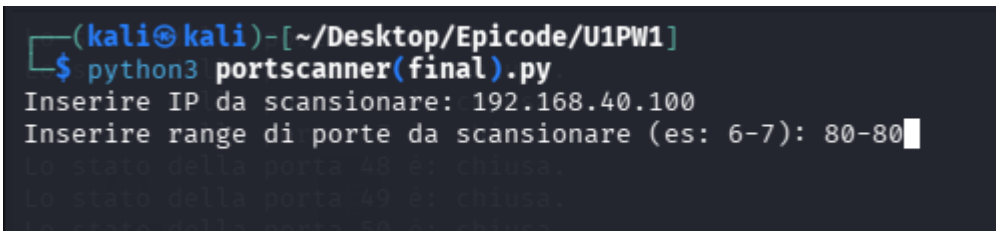
Nonostante l'inclusione di numeri d'errore per ambo i sistemi operativi per una questione di compatibilità, si consiglia l'utilizzo di una macchina Linux, in quanto tutti i test sono stati effettuati su Kali Linux, (Linux 7.1.5, Kali Linux 2026.3).

3.4.2 - Funzionamento e test del programma per l'utente

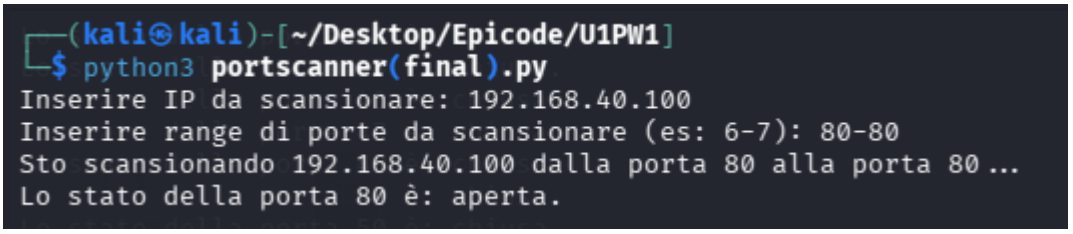
Il codice viene lanciato in terminal tramite python3 portscanner(final).py.
Il programma chiede l'IP da scansionare (tentiamo una connessione all'IP del web server Theta, al momento della simulazione configurato con IP 192.168.40.100):



Richiede poi il range di porte da scansionare, da n porta a n porta (per l'esempio qui proveremo la porta 80):



Il programma infine stampa il risultato: nel test, la porta 80 del webserver Theta è risultata aperta:



È possibile effettuare una scansione di tutte le porte presenti, ma è consigliato l'utilizzo di una stampa a file del risultato visto il grande numero che renderebbe ostica la consultazione a terminale (nel test è stato utilizzato python3 portscanner(final).py | tee scan_output.txt).

I risultati della scansione delle porte well known (da 1 a 1023) verranno allegati al report.

3.4.3 - Raccomandazioni per la sicurezza

La scansione delle porte well known (1 a 1023) ha dato come risultato un totale di 12 porte aperte (21, 22, 23, 25, 53, 80, 111, 139, 445, 512, 513, 514), alcune delle quali associate a protocolli notoriamente conosciuti per le loro vulnerabilità, dirette o indirette. Le seguenti raccomandazioni sono cautelative e si consiglia agli addetti ai lavori di confermare le versioni interne dei servizi e se necessario mettere in atto le seguenti misure.

È di fondamentale importanza assicurarsi, in caso di versioni di protocolli obsolete, di aggiornare alla versione più recente, in quanto svariate vulnerabilità vengono risolte con semplici aggiornamenti.

Si consiglia di sostituire direttamente alcuni servizi obsoleti / passare a versioni più moderne e più sicure, come ad esempio nel caso delle porte 21, 23, 25: servizi FTP, Telnet e SMTP (noti per trasmettere tutti i dati, incluse possibili credenziali, in chiaro, e quindi vulnerabili anche ad un semplice sniffer) con ad esempio FTPS, TelnetS. Nel caso di SMTP ad esempio son presenti varie estensioni pensate per migliorare la sicurezza.

Anche il servizio HTTP sulla porta 80 non cifra il traffico (chiunque può sia leggere che modificare i dati trasmessi) e non fornisce meccanismi di autenticazione integrati.
Una delle possibili soluzioni è attivare e configurare il servizio HTTPS sulla porta 443.

Si consiglia la disattivazione dei servizi nelle porte 512, 513 e 514 (Berkeley r-commands) in quanto totalmente obsoleti e vulnerabili e l'utilizzo di SSH al loro posto.

In merito alle configurazioni, si sottolinea l'importanza di mantenere una corretta configurazione, assicurandosi di non lasciare password predefinite o peggio ancora vuote (come di default in alcuni protocolli) e di utilizzare password complesse, disattivare eventuali accessi anonimi (come nel caso di FTP o SMB). Si ricorda anche di aggiornare e monitorare i vari sistemi di sicurezza, tra cui i firewall, al fine di filtrare il traffico e garantire l'accesso soltanto a reti od host autorizzate ove necessario.

Ciononostante, la migliore raccomandazione possibile è quella di ridurre la potenziale superficie di attacco, lasciando in ascolto solamente i servizi necessari e disattivando quelli superflui.

3.4.4 - Ultime considerazioni

Si consiglia, oltre alle raccomandazioni più tecniche, di assicurarsi della formazione del proprio personale, addestrando ad evitare tecniche di phishing, ricordando di non provare ad accedere a siti malevoli con dispositivi di lavoro, a non utilizzare dispositivi di archiviazione soggetti a facile smarrimento (es. pendrive), e ad utilizzare password complesse e sistemi di autenticazione.
Se possibile si raccomanda di effettuare test Vulnerability Assessment per check up periodici.

4 - Preventivo

Per quanto riguarda la gestione del budget, abbiamo optato per una soluzione a favore del miglior rapporto qualità/prezzo.
A seguire le spese per gli apparati:

Strumento	Quantità	Prezzo
Router ISR4331	x1	1300,00 €
Firewall Enterprise	x1	6.000,00 €
Firewall Software	x1	3.000,00 €
Switch	x8	800,00 € pz. = 6400,00 €
Multi-layer Switch	x1	450,00 €
IDS	x2	1500,00€ pz. = 3000,00€
IPS	x1	2500,00€ pz. = 2500,00€
Server	x3	5000,00 € pz. = 15.000,00 €
Totale:		**37.650,00 €**

Nel calcolo del budget si conteggia anche il cablaggio con i vari componenti, quindi:

- **Cavi Cat6/Cat6A** da: 2000,00 €
- **Patch Panel** da: 1000,00 €
- **Armadi Rack** da: 3500,00 €
- **Prese RJ45** e connettori da: 800,00 €
- **Canaline e accessori** da: 2000,00 €

Per un **totale** nel costo del cablaggio di 9.300,00 €

Un altro aspetto da considerare per calcolare il budget da spendere è il tempo investito nella configurazione del router, degli switch, del firewall e di tutto ciò che ne consegue. Quindi adesso vedremo:

Le configurazioni per il nostro progetto di: 120 PC, 6 VLAN, 1 router, 8 switch access + 1 multilayer switch, 2 firewall, 2 IDS e 1 IPS, una stima realistica sarebbe:

- **La configurazione delle VLAN** e assegnazione porte: dalle 3 alle 5 ore
- **Il Routing**: dalle 2 alle 4 ore
- **Configurazione switch**: dalle 4 alle 7 ore
- **Configurazione Multi-layer Switch**: dalle 3 alle 5 ore
- **Firewall**: dalle 4 alle 7 ore
- **Test di connettività**: dalle 2 alle 4 ore
- **Risoluzione problemi e ottimizzazione**: dalle 4 alle 8 ore

Per un range compreso tra 22 e 40 ore

Se aggiungiamo anche:

- **Documentazione tecnica**;
- **Script Python per i test HTTP**;
- **Script Python per la scansione delle porte**;
- **Esecuzione dei test e redazione del report finale**;

Allora il progetto completo può tranquillamente richiedere dalle 50 alle 80 ore.

Calcolando nel budget anche le ore di lavoro, e facendo una stima del valore totale, si può presumere che si possano pagare almeno 50 €/h.

Quindi si può stimare un pagamento per:” 50€/h x 65h = 3250,00 €

Preventivo Finale

Ricapitolando i costi per questo progetto, abbiamo:

- 40.600,00 € di apparati;
- 9.300,00 € di cablaggio e ciò che ne consegue;
- +/- 65h di lavoro alla paga oraria di 50€, per un totale di 3250,00 €;

Spesa	IVA (22%)	Prezzo Finale
50.200,00 €	11.044,00 €	61.244,00 €

Spese totali per 50.200,00 € a cui si aggiunge l'IVA al 22% che raggiunge gli 11.044,00 €, per un totale di 61.244,00 €